Module 09: Active Directory Penetration Testing

```
# Exercise 06: Enumerating Active Directory with Nmap and Using NetExec to Access SMB Shared Folder
```

Scenario

Active Directory domain identification and credential brute-forcing across Server Message Block (SMB) protocols form critical early steps in network security assessments. By scanning LDAP services (`TCP 389`) across subnet ranges, penetration testers can quickly pinpoint active Domain Controllers and extract domain metadata, operating system builds, and primary FQDNs.

Once a Domain Controller is located, utility suites such as **NetExec** (`nxc`) allow testers to audit SMB authentication services (`TCP 445`), evaluate password spraying vulnerability using wordlists like `rockyou.txt`, enumerate hidden administrative disk shares (`--shares`), and verify share access over SMB (`smb://192.168.177.19/C$`). In this exercise, we scan the **192.168.177.0/24** subnet with Nmap to discover Domain Controller **192.168.177.19** (**SERVER2019.lpt.com**), execute NetExec SMB password brute-forcing against **Administrator**, obtain valid credentials (**Pa$$w0rd**), enumerate administrative SMB shares, and establish GUI share access to `C$` via GTK file manager.

Objective

The objective of this lab is to help students learn how to:
- Identify Active Directory Domain Controllers on a subnet using aggressive LDAP port scanning (**sudo nmap -p 389 -T4 -A 192.168.177.0/24**)
- Extract DC FQDN details (**SERVER2019.lpt.com**) from Nmap script LDAP outputs
- Verify target SMB service availability using NetExec (**nxc smb 192.168.177.19**)
- Execute targeted dictionary attacks against domain accounts using NetExec: **nxc smb 192.168.177.19 -u 'Administrator' -p /usr/share/wordlists/rockyou.txt --ignore-pw-decoding**
- Enumerate SMB share permissions with valid domain credentials via **nxc smb 192.168.177.19 -u 'Administrator' -p 'Pa$$w0rd' --shares**
- Mount remote administrative shares using SMB GUI path (**smb://192.168.177.19/C$**) and validate administrative access

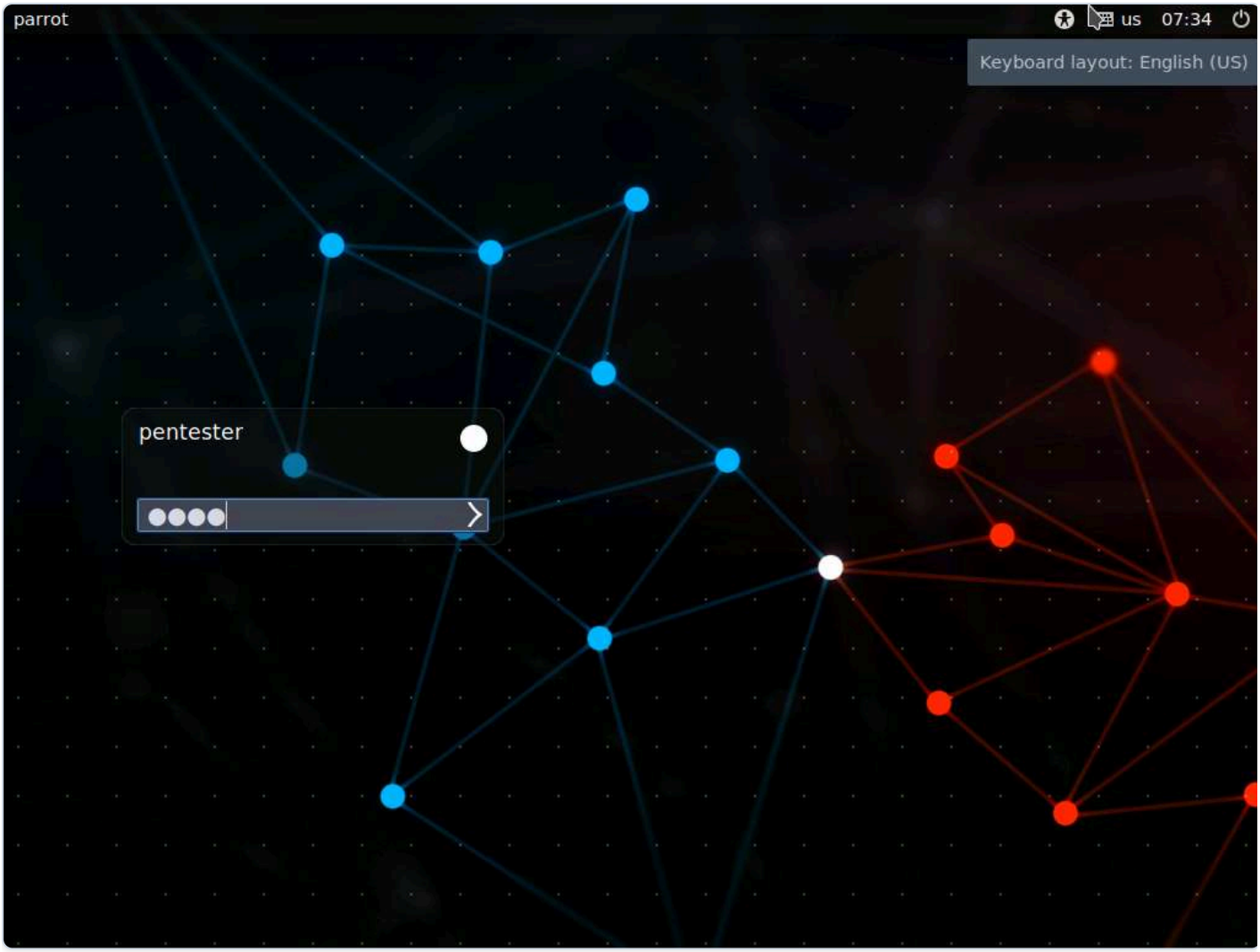
---

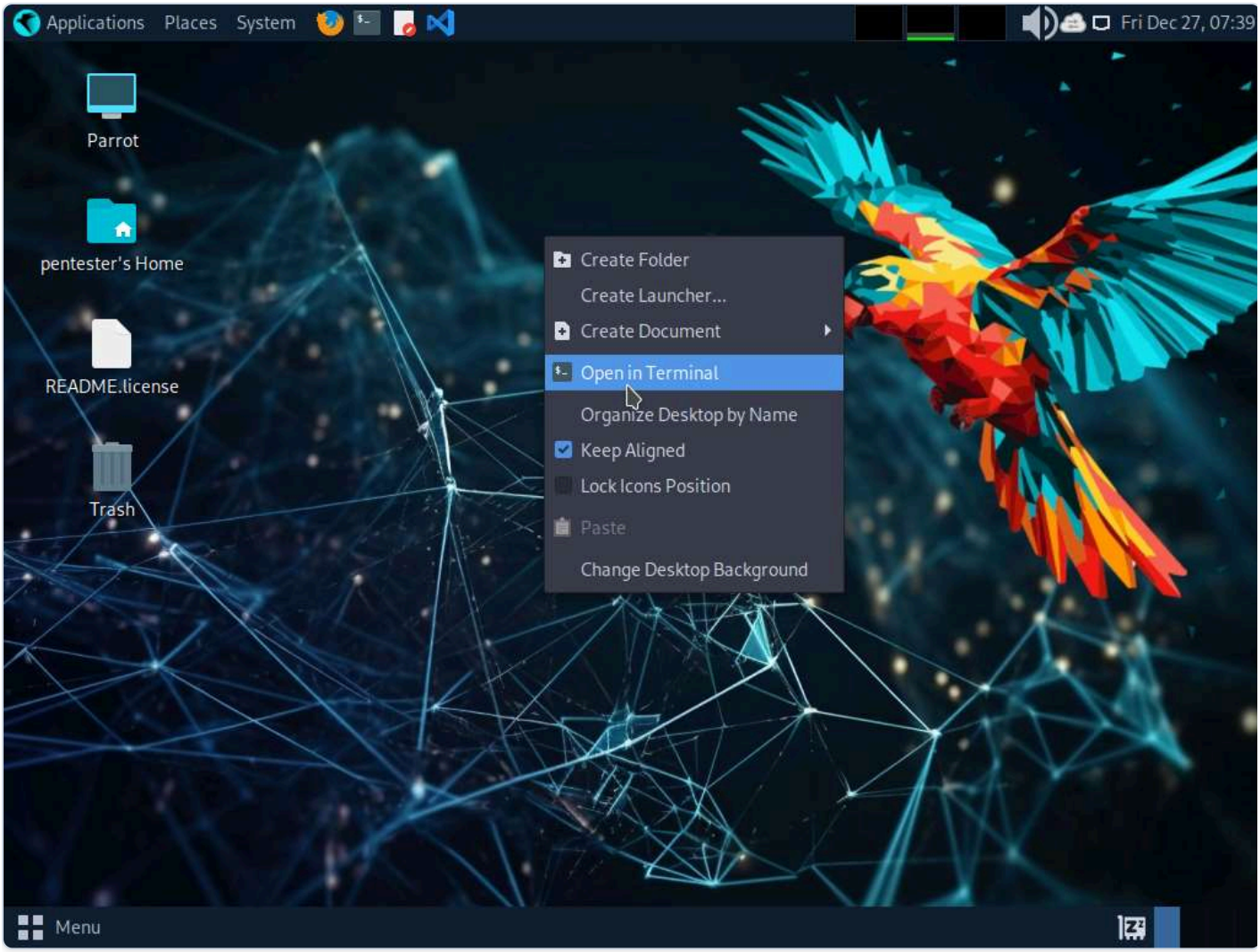
Task 1: Perform LDAP Network Reconnaissance, NetExec SMB Brute-Forcing, and Remote Share Access

In this task, we scan **192.168.177.0/24** to locate Domain Controller **192.168.177.19** (**SERVER2019.lpt.com**), brute-force SMB credentials with NetExec and `rockyou.txt`, enumerate shares, and connect to `C$` share.

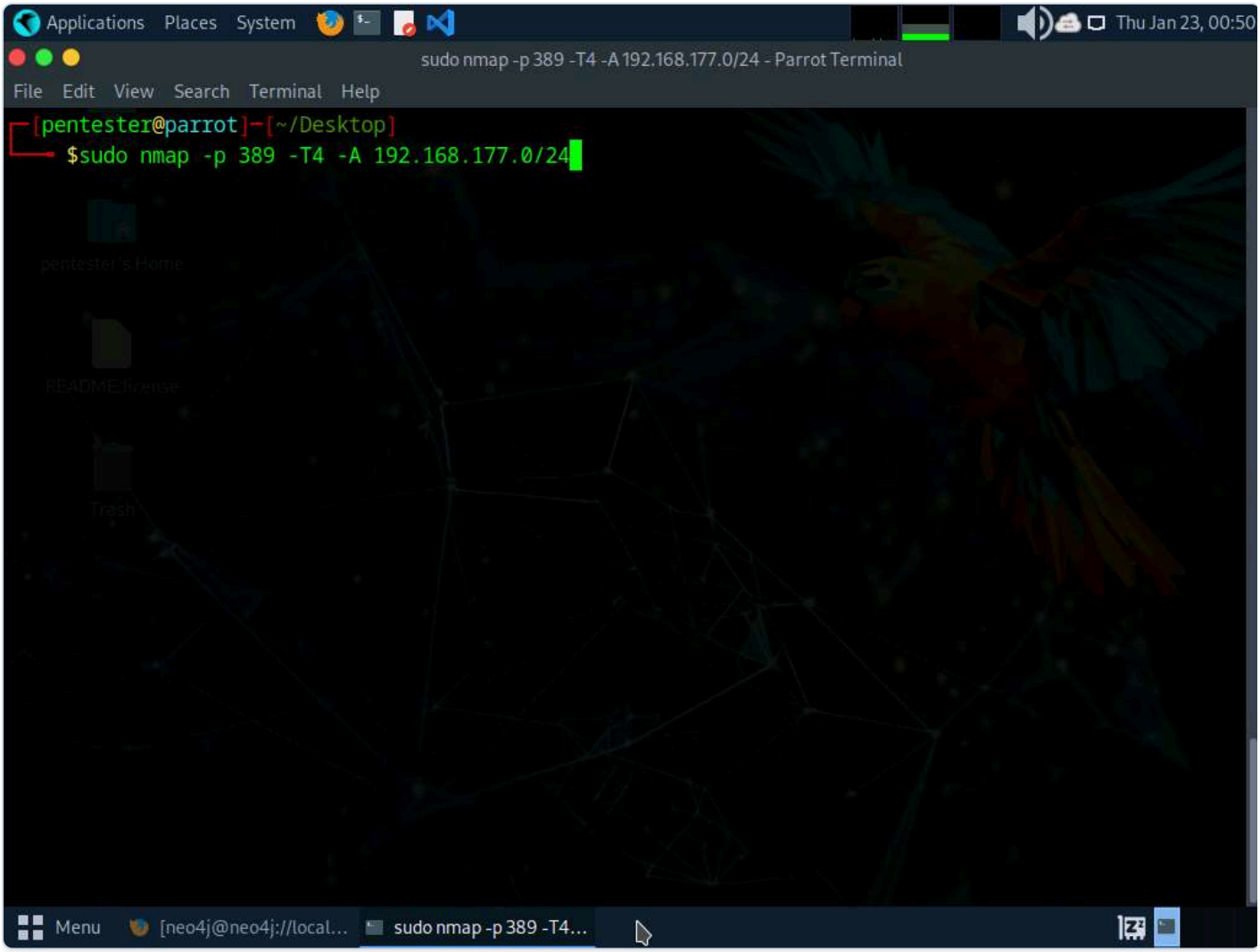
Lab Tasks

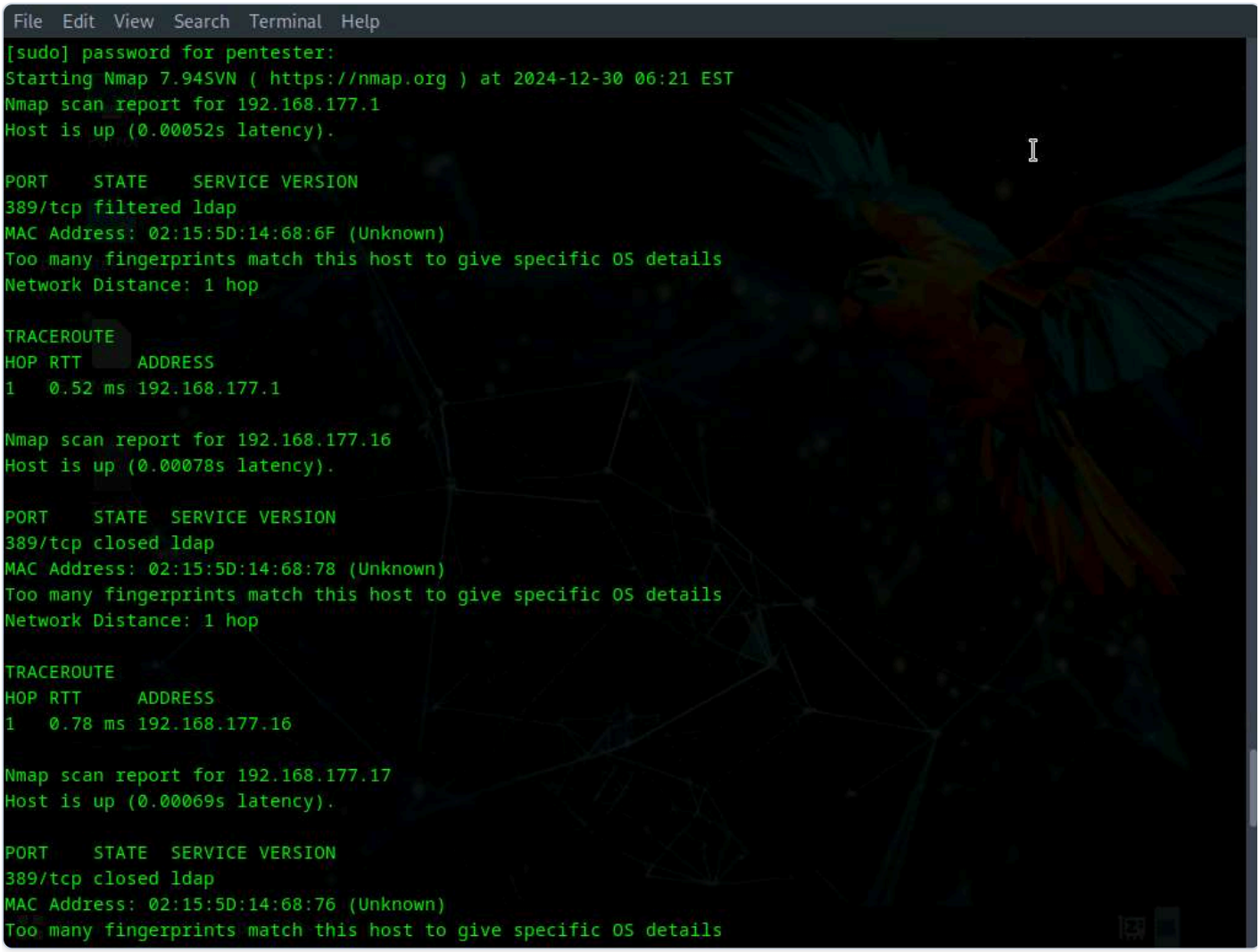
1. Switch to **Parrot Security** machine and open terminal.


parrot
us
07:34
Keyboard layout: English (US)
pentester

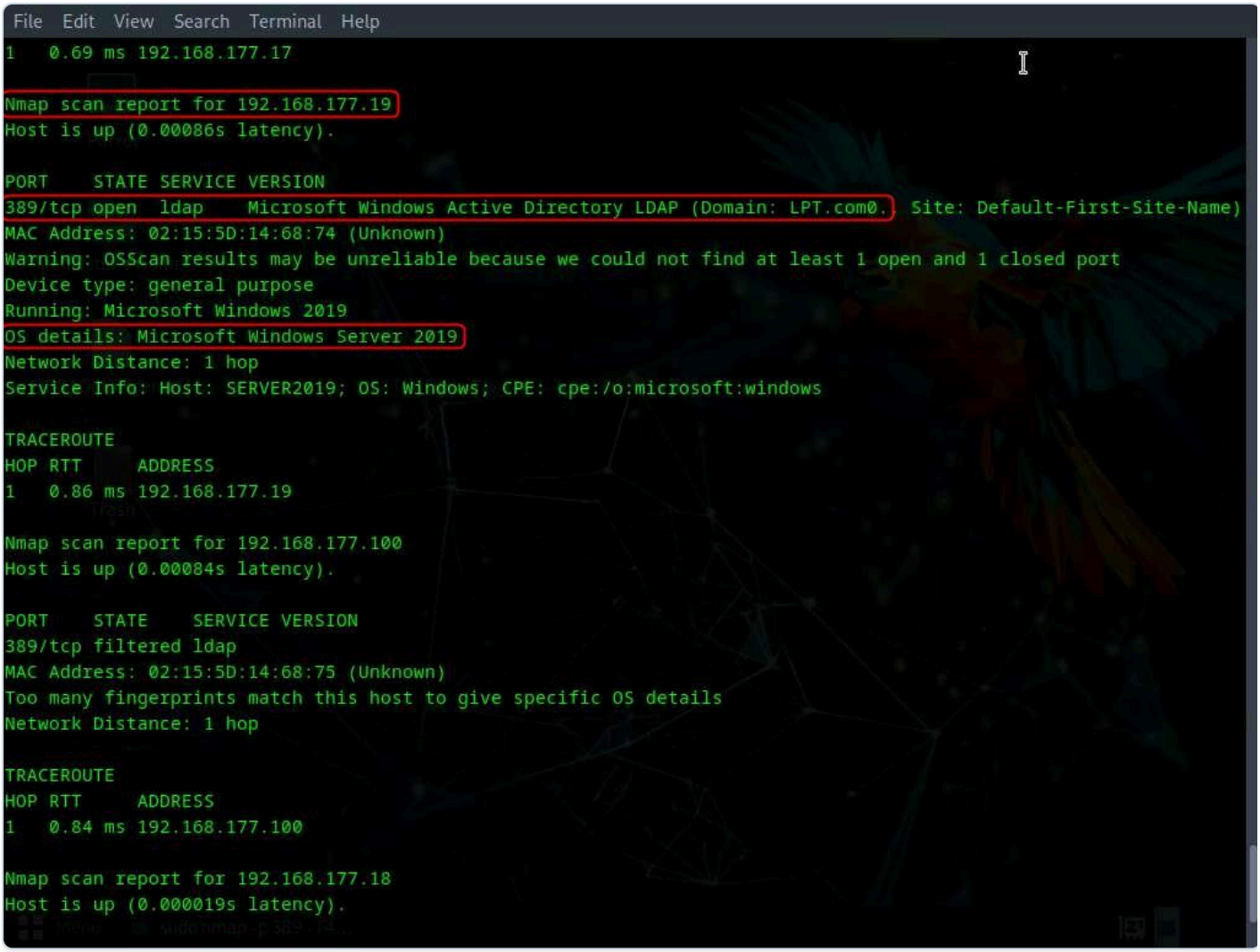


1. Run aggressive Nmap scan targeting LDAP port 389 across the subnet range:
   sudo nmap -p 389 -T4 -A 192.168.177.0/24
   Password for sudo: **toor**

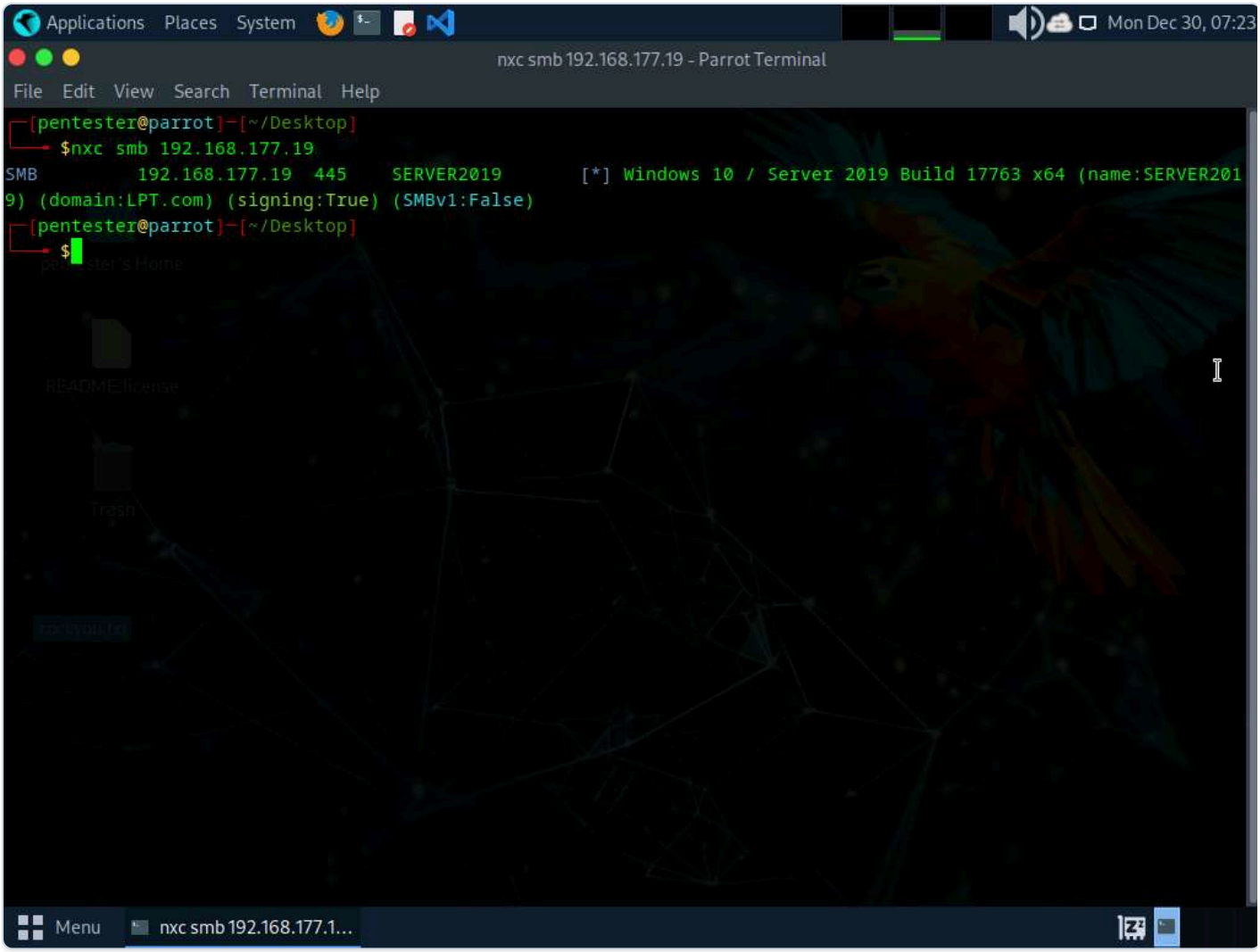

Applications
Places
System
Thu Jan 23, 00:50
sudo nmap -p 389 -T4 -A 192.168.177.0/24 - Parrot Terminal
File
Edit
View
Search
Terminal
Help
[pentester@parrot]-[~/Desktop]
$sudo nmap -p 389 -T4 -A 192.168.177.0/24
pentester's Home
README.license
Trash
Menu
[neo4j@neo4j://local...
sudo nmap -p 389 -T4...



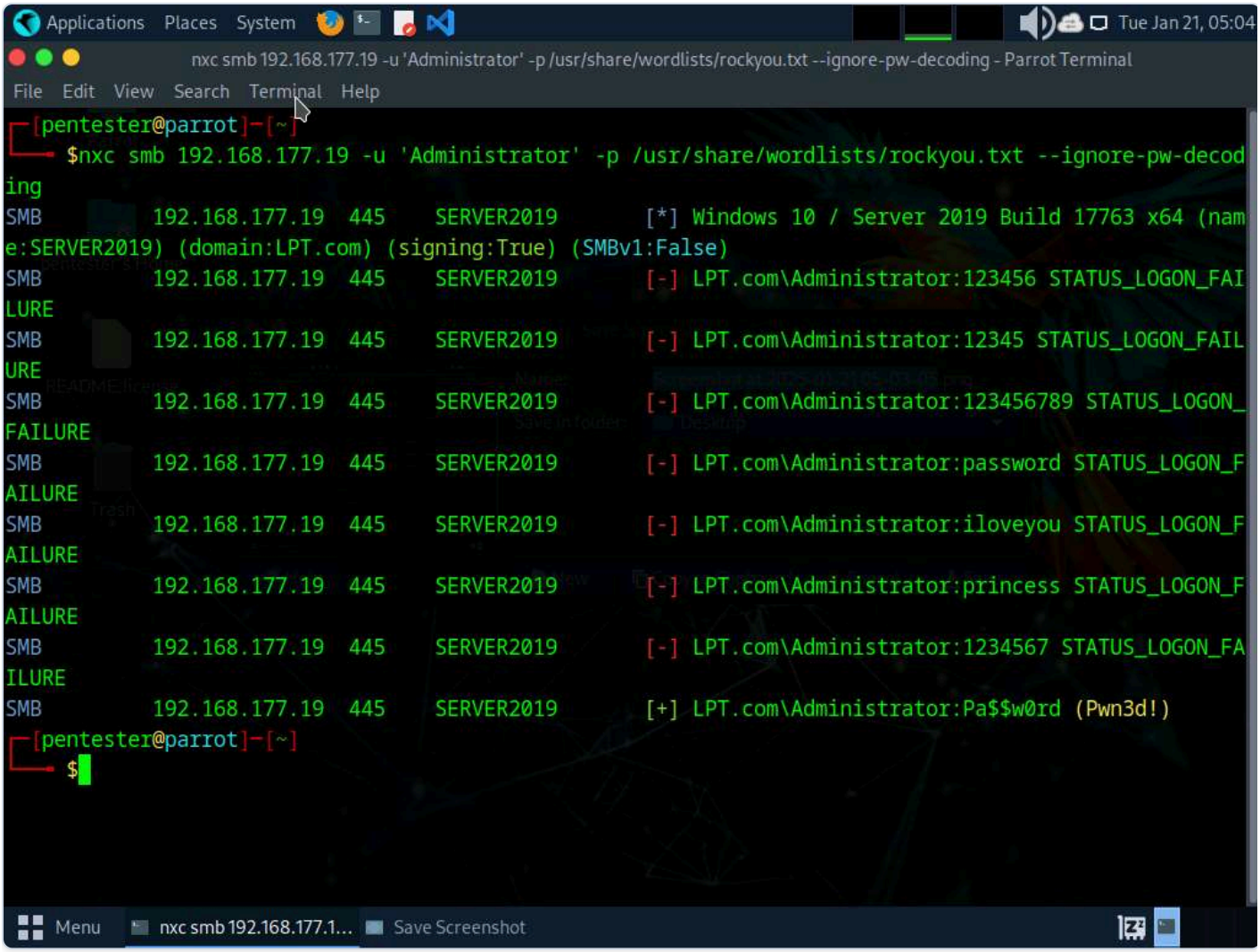
1. Review scan results for **192.168.177.19** running Windows Server 2019 and note the primary DNS domain name: **SERVER2019.lpt.com**.



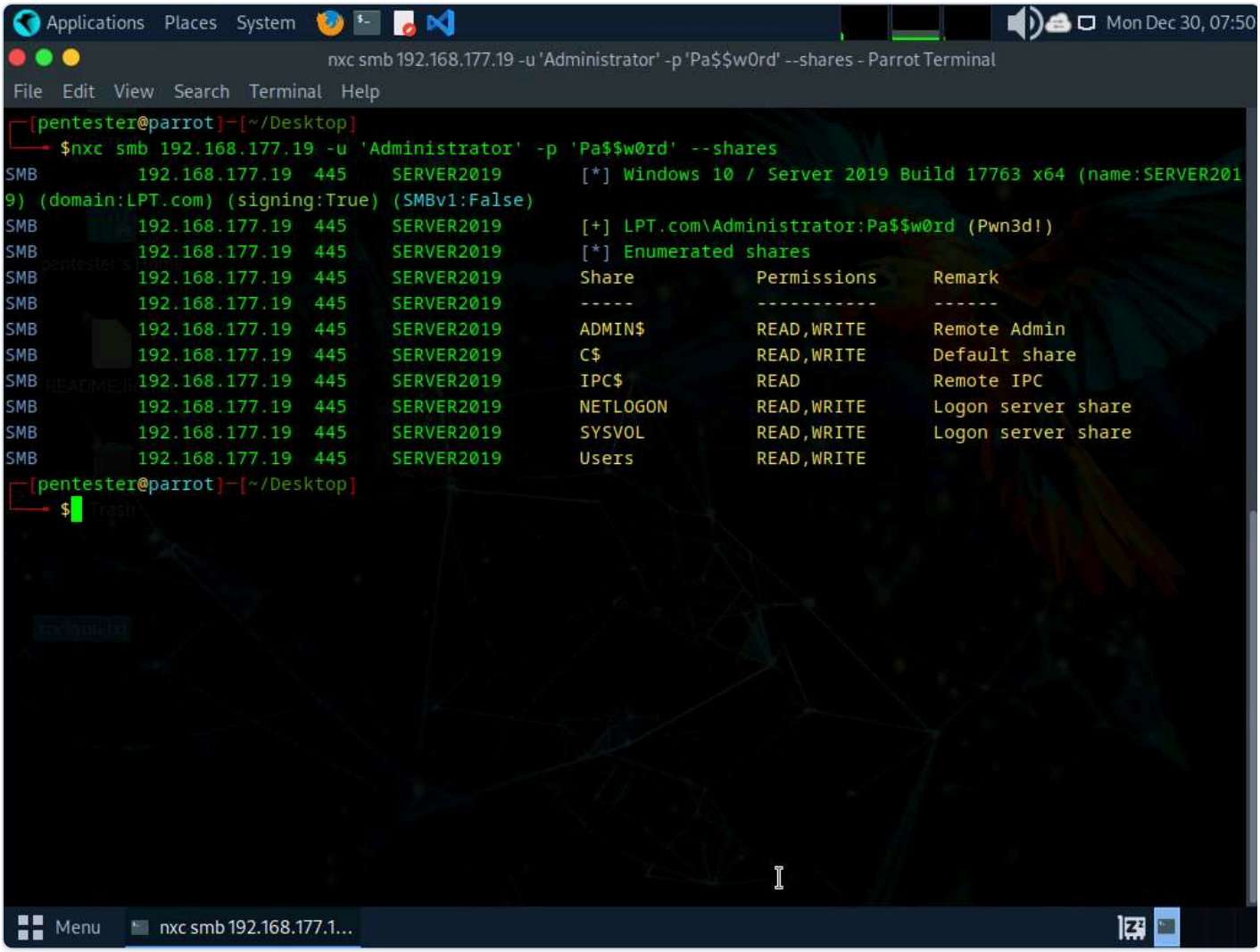
1. Verify SMB service availability on the Domain Controller:
   nxc smb 192.168.177.19



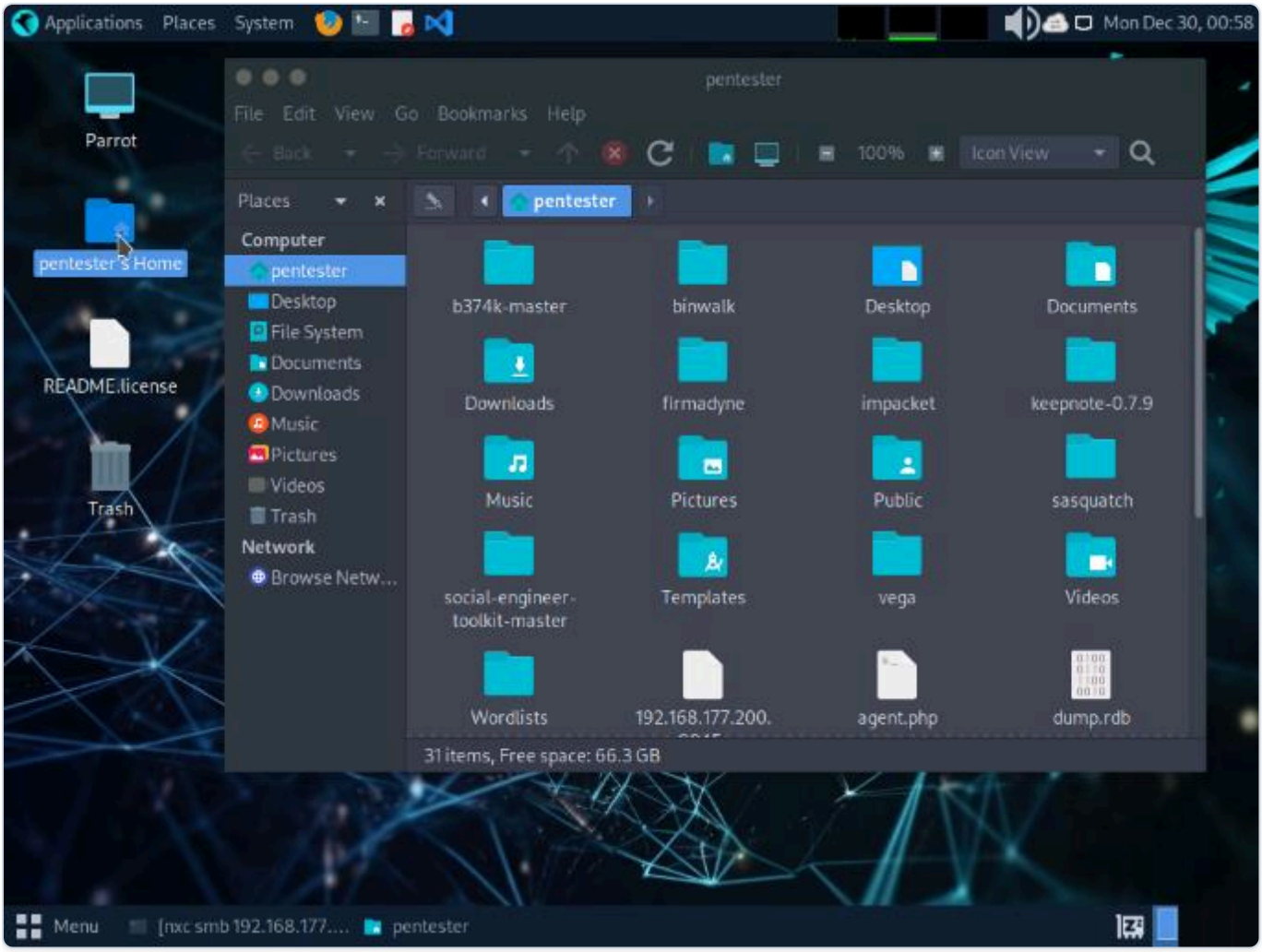
1. Execute NetExec dictionary attack against `Administrator` account using `rockyou.txt`:
   nxc smb 192.168.177.19 -u 'Administrator' -p /usr/share/wordlists/rockyou.txt --ignore-pw-decoding
   Observe valid credential match: **Pa$$w0rd** (`Pwn3d!`).



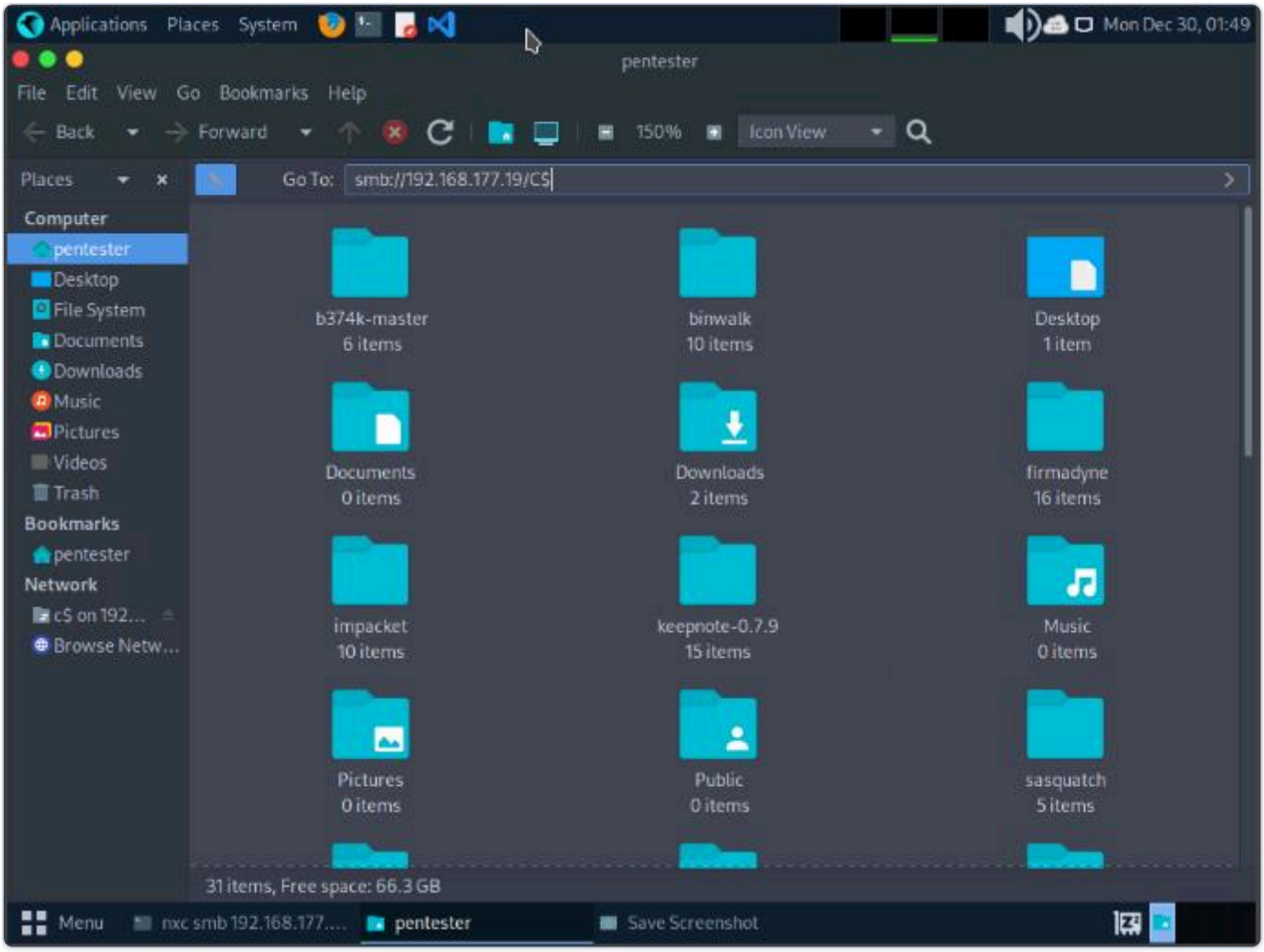
1. Enumerate available SMB shares and access permissions using verified credentials:
   nxc smb 192.168.177.19 -u 'Administrator' -p 'Pa$$w0rd' --shares



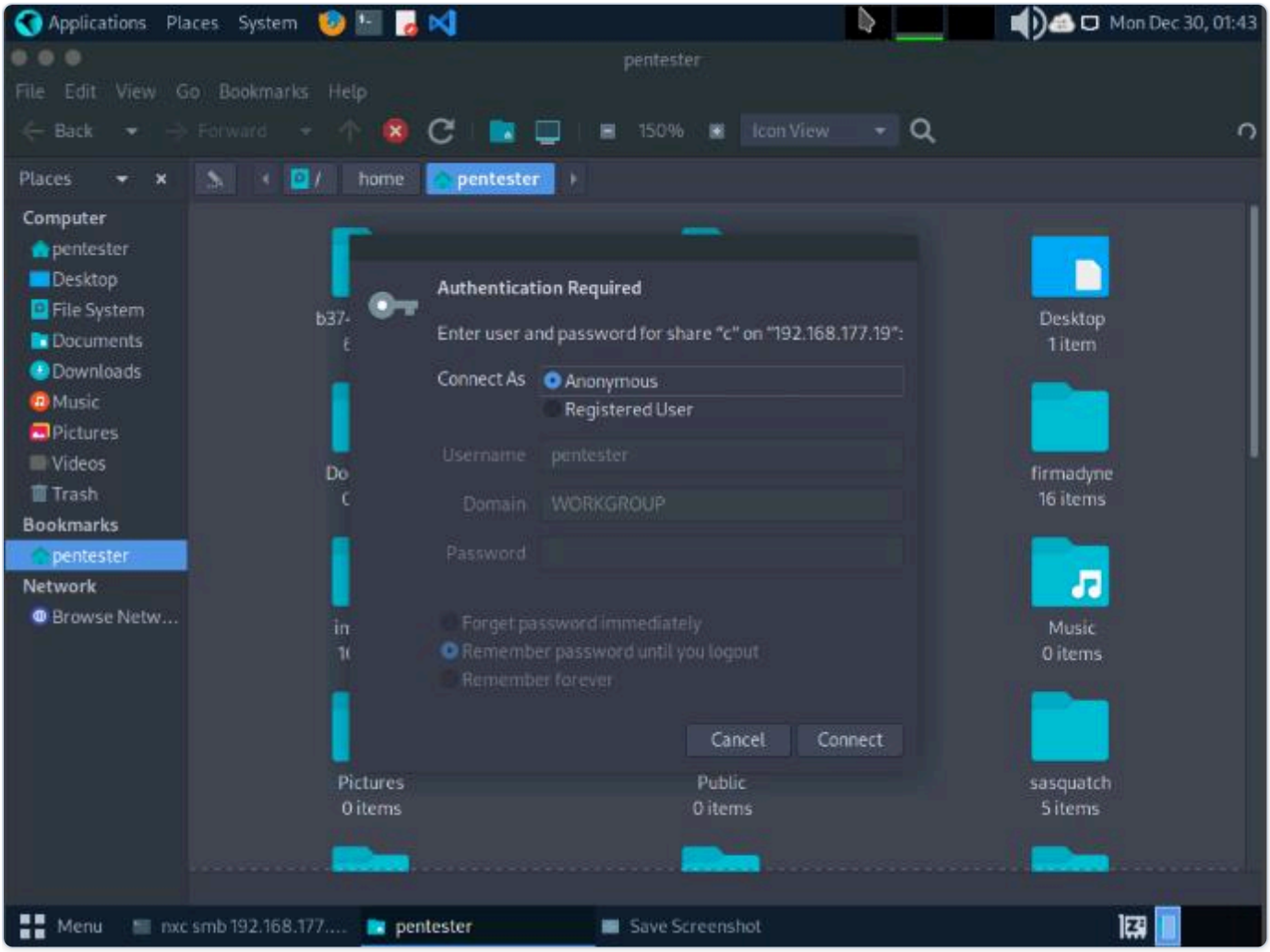
1. Open pentester's Home folder on Desktop.

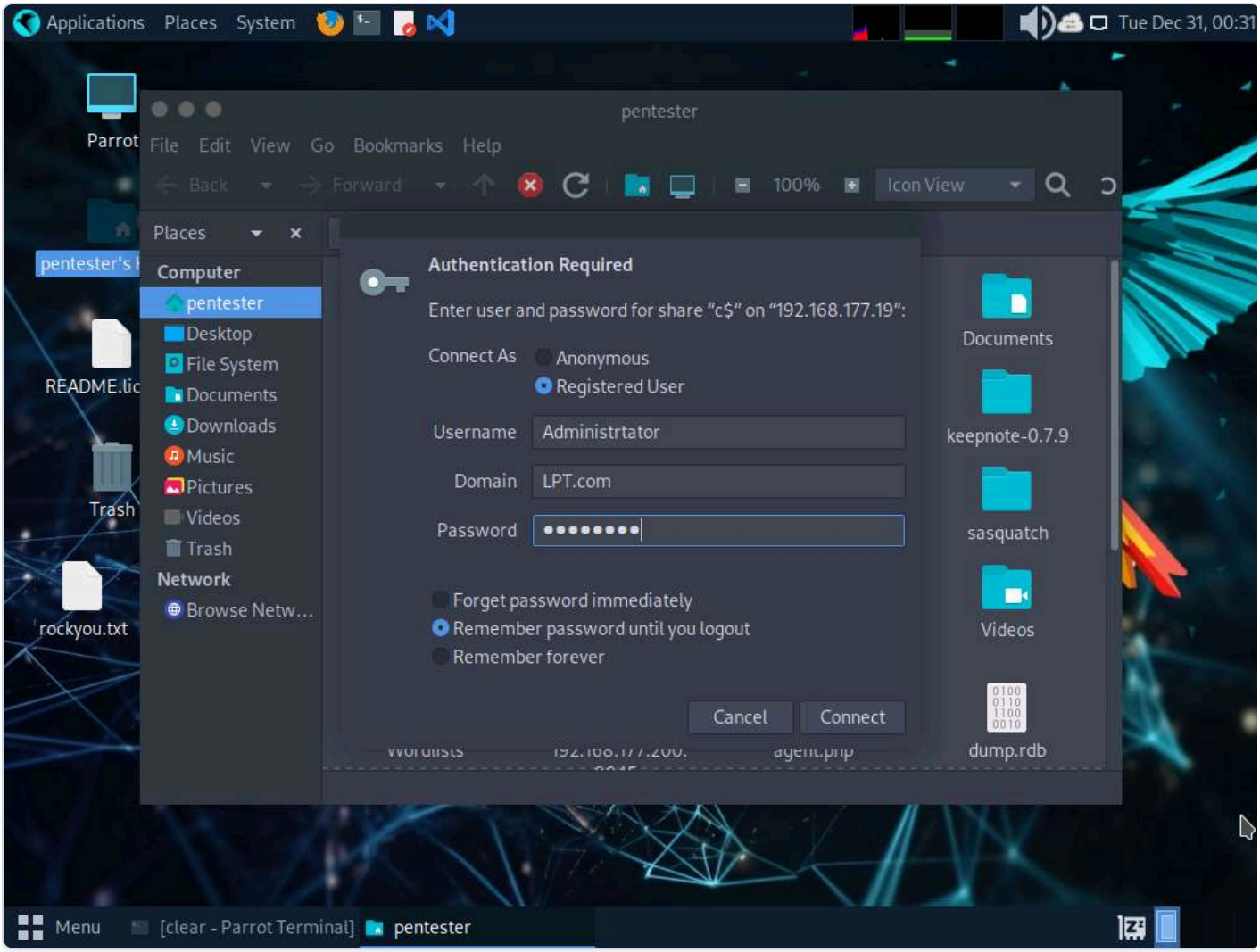


1. Press `Ctrl+L` and enter remote SMB URI:
   smb://192.168.177.19/C$

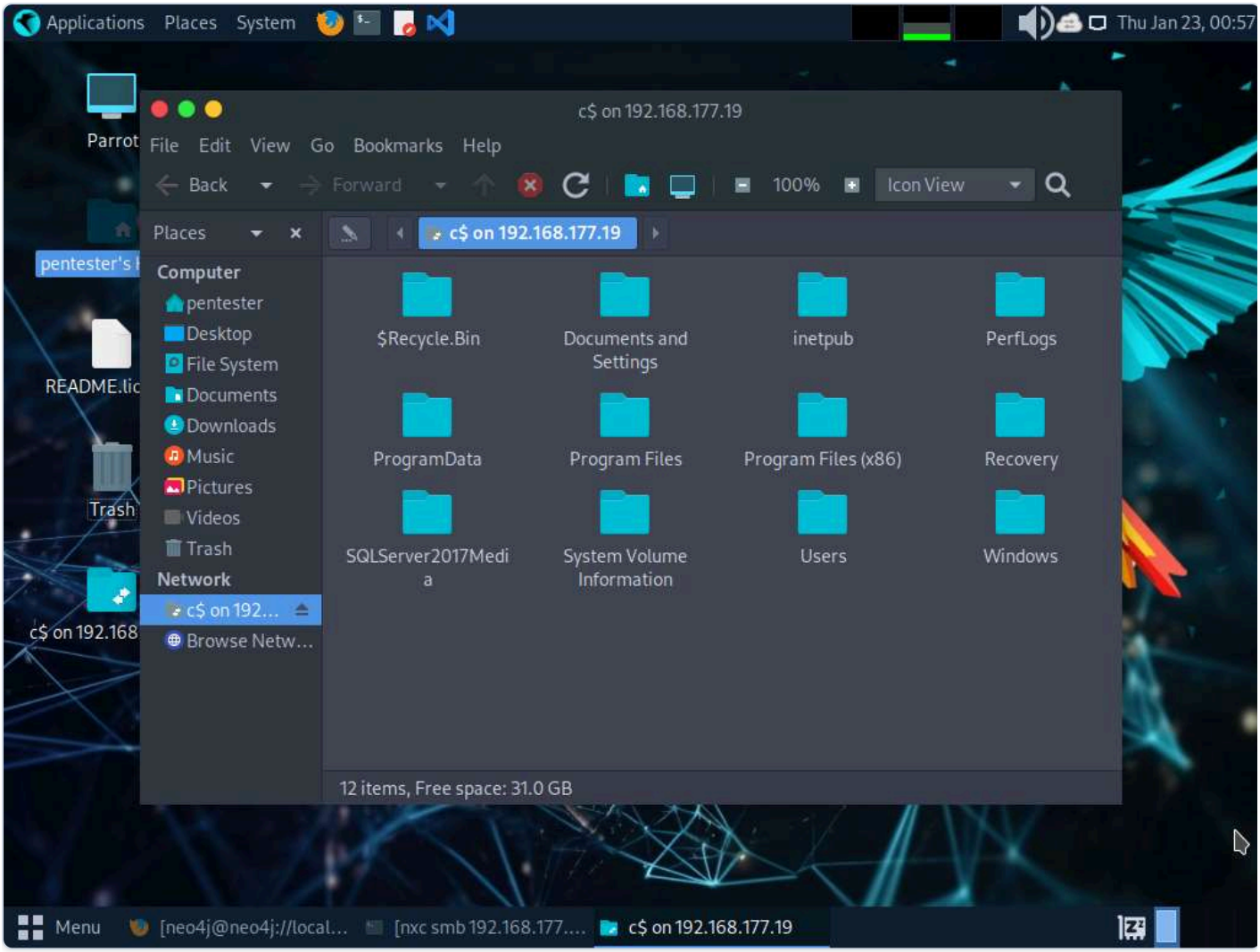


1. In authentication prompt, select **Registered User**, enter Username **Administrator**, Domain **LPT.com**, and Password **Pa$$w0rd**, then click **Connect**.


Applications Places System
Mon Dec 30, 01:43
pentester
File Edit View Go Bookmarks Help
Back Forward 150% Icon View
Places
/ home pentester
Computer
pentester
Desktop
File System
Documents
Downloads
Music
Pictures
Videos
Trash
Bookmarks
pentester
Network
Browse Netw...
Authentication Required
Enter user and password for share "c" on "192.168.177.19":
Connect As Anonymous
Registered User
Username pentester
Domain WORKGROUP
Password
Forget password immediately
Remember password until you logout
Remember forever
Cancel Connect
Desktop
1 item
firmadyne
16 items
Music
0 items
sasquatch
5 items
Pictures
0 items
Public
0 items
Menu
nxc smb 192.168.177....
pentester
Save Screenshot



1. Confirm successful browsing access to target Domain Controller `C$` drive.



This concludes the lab exercise.

IMPORTANT: ❓ **Question 9.6.1.1** Using a Parrot Security machine, conduct an Nmap scan to identify the domain controller. Utilize NetExec to perform a brute-force attack on the domain controller, targeting the Administrator account with common passwords from the RockYou wordlist to obtain valid credentials. Finally, retrieve and enter the DNS name of the 192.169.177.19 machine as identified in the Nmap scan. [!SUCCESS] ✅ **Answer:** **SERVER2019.lpt.com**